



Bella Spa ERP

BÁO CÁO ĐÁNH GIÁ TOÀN DIỆN

 20/05/2026

 v2.0 Production

 Source Code Audit

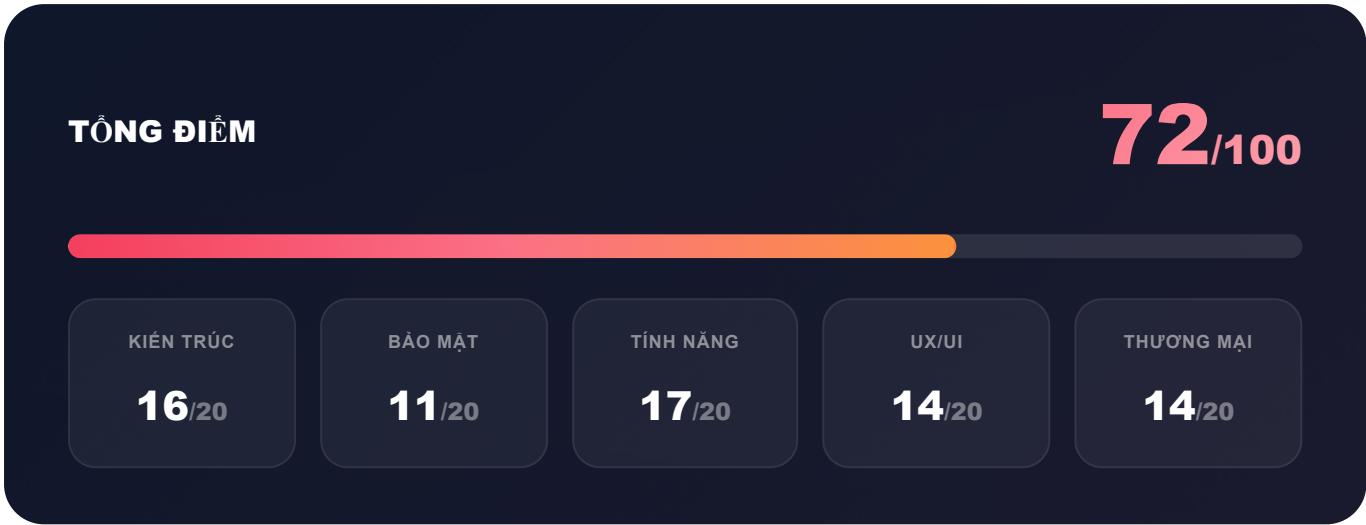
72 / 100

TỔNG ĐIỂM ĐÁNH GIÁ



Tổng Quan Điểm Đánh Giá

Phân tích và chấm điểm dựa trên 5 tiêu chí: Kiến trúc, Bảo mật, Tính năng, UX/UI, và Khả năng thương mại hóa. Mỗi tiêu chí chiếm 20% trọng số.



1 Cấu Trúc & Kiến Trúc Mã Nguồn — 16/20

Điểm mạnh

HẠNG MỤC	ĐÁNH GIÁ	CHI TIẾT
Tech Stack hiện đại	★★★★★	Next.js 16 App Router + Supabase + Tailwind CSS v4 + Framer Motion — Stack enterprise-grade tiên tiến nhất 2026
Service Layer tách biệt	★★★★☆	17 file service actions phân chia theo domain: booking, salary, finance, CRM, inventory, attendance, audit...
Database Migrations	★★★★★	30 migration files version-controlled, incremental — lịch sử phát triển schema minh bạch, reproducible
Multi-tenant Architecture	★★★★☆	tenant_id trên TOÀN BỘ 16+ bảng. Shared Database, Shared Schema — chuẩn SaaS pattern
Offline-First (Dexie.js)	★★★★★	IndexedDB queue + FIFO sync + auto-retry — KTV hoạt động liên tục khi mất mạng. Rất hiếm trên thị trường VN
Server Action Pattern	★★★★☆	Tất cả service dùng 'use server', đúng Next.js App Router. Không leak logic phía client

Điểm yếu cần cải thiện

VẤN ĐỀ	MỨC ĐỘ	GIẢI PHÁP ĐỀ XUẤT
Không có unit/integration test	NGHIÊM TRỌNG	0 file test. Cần tối thiểu test cho salary calculation, booking lifecycle, finance P&L
Type Safety lỏng lẻo	TRUNG BÌNH	Sử dụng "as any" >50 lần. Cần strongly-typed Supabase generated types
File service quá lớn	TRUNG BÌNH	booking-actions.ts = 59KB (1,713 dòng), salary-actions.ts = 34KB. Khó maintain
Middleware không chuẩn	TRUNG BÌNH	proxy.ts chỉ refresh token, không enforce auth trước khi vào /dashboard/*

2 Bảo Mật — 11/20

Điểm mạnh

HẠNG MỤC	ĐÁNH GIÁ	CHI TIẾT
RLS (Row Level Security)	★★★★☆	Supabase RLS bật trên các bảng chính. Mỗi query filter tenant_id
Audit Logging	★★★★☆	recordAuditLog() ghi nhận INSERT/UPDATE/DELETE trên tất cả bảng nghiệp vụ
RBAC 4 cấp	★★★★☆	admin, ktv_lead, ktv, admin_staff — phân quyền sidebar + data access, configurable per tenant
OAuth token auto-refresh	★★★★☆	Zalo access token tự động refresh với 5-phút buffer, masked secrets

Điểm yếu NGHIÊM TRỌNG

⚠️ Lỗi hỏng #1: Hardcoded tenant_id fallback

Giá trị tenant_id mặc định xuất hiện >15 lần trong code. Nếu session expire → user có thể truy cập/ghi data vào tenant khác.

CẦN FIX NGAY trước khi thương mại hóa.

VẤN ĐỀ	MỨC ĐỘ	CHI TIẾT
Hardcoded tenant fallback	CỰC KỲ NGUY HIỂM	Nếu session expire → data ghi vào tenant mặc định thay vì báo lỗi
Dev mock user bypass	RỦI RO CAO	Mock admin qua cookie trong dev mode. NODE_ENV sai → bypass toàn bộ auth
Không có CSRF protection	TRUNG BÌNH	API webhooks cần thêm token verification
Không có rate limiting	TRUNG BÌNH	Booking form, Zalo API không có throttle → có thể bị abuse
Zalo credentials plaintext	TRUNG BÌNH	zalo_secret_key lưu plaintext trong DB. Nên encrypt hoặc dùng secret manager

3 Tính Năng & Nghiệp Vụ — 17/20

Ma trận tính năng

Module	Trạng Thái	Độ Sâu	Ghi Chú
Dashboard tổng quan	✓ PRODUCTION	★★★★☆	Realtime stats, charts, revenue overview
Quản lý Khách hàng	✓ PRODUCTION	★★★★☆	CRM đầy đủ: thông tin mẹ+bé, membership tiers
Đặt lịch & Booking	✓ PRODUCTION	★★★★☆	Full lifecycle: inquiry → deposit → completed
Thẻ liệu trình	✓ PRODUCTION	★★★★☆	Session log, completion tracking, KTV GPS check-in/out
Tài chính P&L	✓ PRODUCTION	★★★★☆	Revenue, Expense, automated P&L, cash flow
Bảng lương KTV	✓ PRODUCTION	★★★★☆	Auto-calc: base + KPI + service % + pro-rata deduction
Kho hàng & Auto-consume	✓ PRODUCTION	★★★★☆	Stock tracking, auto-deduct per session
CRM & Zalo ZNS	✓ PRODUCTION	★★★★☆	Real Zalo API, batch reminders, birthday campaigns
Chat nội bộ	✓ PRODUCTION	★★★★☆	Internal threads, file attachments
Chấm công & Nghỉ phép	✓ PRODUCTION	★★★★☆	GPS check-in, shift mgmt, leave approval
KTV Mobile Dashboard	✓ PRODUCTION	★★★★☆	Earnings view, schedule, offline check-in
Audit Trail	✓ PRODUCTION	★★★★☆	Full CRUD trail on all tables
Landing Page	✓ PRODUCTION	★★★★☆	1528-line premium, booking wizard, responsive
Customer Portal	● BETA	★★★☆☆	Token-based access, cơ bản
Multi-branch	✗ CHƯA CÓ	—	Chỉ có schema + spec, chưa triển khai UI

💡 Tính năng nổi bật (Unique Selling Points)

🔌 Offline-First Architecture

Dexie.js IndexedDB queue. KTV check-in/out khi mất mạng, tự sync khi online. Không PM spa VN nào có.

💬 Zalo ZNS Real API

Tích hợp Zalo OA thực tế, tự động nhắc lịch 2.5h trước, gửi voucher sinh nhật. Token auto-refresh.

💰 Salary Calculation Engine

Pro-rata deduction: nghỉ phép → trừ ngày, KPI achievement rate, service %. Phức tạp ngang ERP lớn.

📦 Auto-Inventory Consumption

KTV hoàn thành buổi → tự động trừ vật tư theo package_materials mapping. Không cần nhập tay.

4 UX/UI Thân Thiện & Dễ Sử Dụng — 14/20

✔ Điểm mạnh

HẠNG MỤC	ĐÁNH GIÁ
Design System Premium (Glassmorphism)	★★★★★
Landing Page chất lượng cao	★★★★★
Vietnamese localization 100%	★★★★★
Sidebar navigation RBAC	★★★★☆
Framer Motion animations	★★★★☆
Custom PremiumSelect	★★★★☆

⚠ Điểm yếu

VẤN ĐỀ	MỨC ĐỘ
Admin dashboard chưa responsive mobile	
Thiếu Dark Mode	
Thiếu Skeleton loading	
Không có Global Search (Cmd+K)	
Không có Onboarding tour	
Không có Keyboard shortcuts	

5 Khả Năng Mở Rộng & Thương Mại Hóa — 14/20

✔ Sẵn sàng

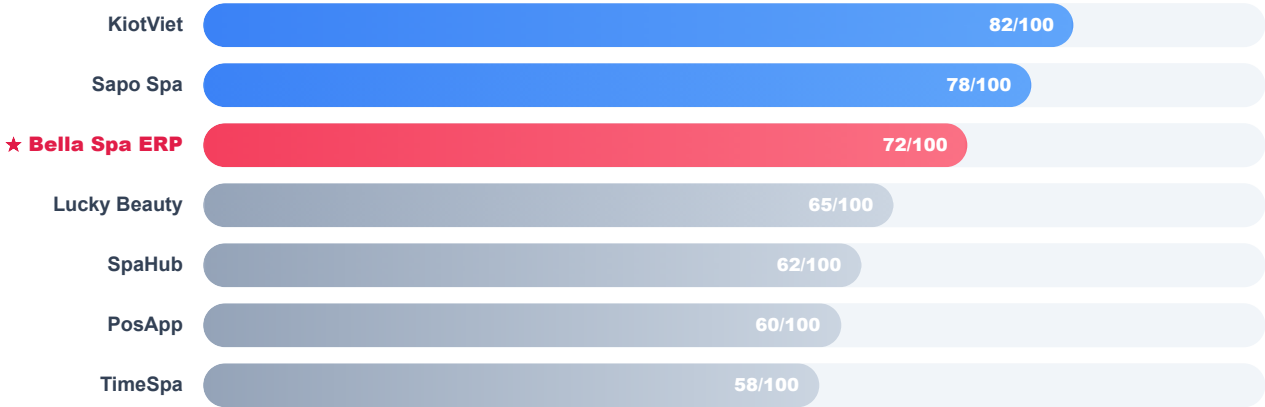
HẠNG MỤC	ĐÁNH GIÁ
Multi-tenant core ready	★★★★☆
Config per-tenant (salary, Zalo, bank)	★★★★☆
Supabase scalability (Postgres)	★★★★☆
Migration versioning (30 files)	★★★★★
Dynamic role permissions JSONB	★★★★☆

⚠ Rào cản thương mại hóa

RAO CẢN	MỨC ĐỘ
Thiếu Self-service Onboarding	
Thiếu Billing/Subscription	
Thiếu Admin Super-Panel	
Thiếu API documentation	
Thiếu CI/CD pipeline	

 So Sánh Với Đối Thủ Tại Việt Nam

Biểu đồ điểm tổng so sánh



Mã trận tính năng đối sánh

TÍNH NĂNG	BELLA SPA	KIOTVIET	SAPO	POSAPP	SPAHUB	LUCKY BEAUTY
Booking / Lịch hẹn	✓	✓	✓	✓	✓	✓
Thẻ liệu trình chuyên sâu	✓ Full	✗	⚠	⚠	✓	✓
Bảng lương tự động + KPI	✓ Pro	✗	✗	✗	✗	⚠
Tài chính P&L tự động	✓	✓	✓	⚠	✗	⚠
Zalo OA/ZNS Integration	✓ Real API	✗	✗	✗	✓ Mini App	✗
Offline-First	✓ Unique	✗	✗	✗	✗	✗
Multi-tenant / Franchise	✓ Ready	✗	⚠	✗	✗	✗
RBAC phân quyền động	✓ 4+ roles	⚠	⚠	⚠	⚠	⚠
Full Audit Trail	✓	✗	✗	✗	✗	✗
GPS Check-in/out KTV	✓	✗	✗	✗	✗	✗
Kho + Auto-consume	✓	✓	✓	✓	✗	✓
Home-care service model	✓ Core	✗	✗	✗	✗	✗

 **Phân tích:** Bella Spa ERP đứng #3 trên thị trường VN về điểm tổng, chỉ thua KiotViet và Sapo — hai nền tảng phát triển 10+ năm. Tuy nhiên, Bella ERP vượt trội hoàn toàn về chiều sâu nghiệp vụ spa chuyên biệt: chăm sóc tại nhà, lương-KPI tự động, offline-first, Zalo ZNS real API, audit trail.

Roadmap Cải Thiện Để Đạt 85+ Điểm

Phase 1: Bảo mật & Ổn định (72 → 78)

- ☐ Xóa hardcoded tenant fallback — throw error
- ☐ Bảo vệ dev mock bypass — env variable riêng
- ☐ Thêm Zod validation cho tất cả Server Actions
- ☐ Rate limiting cho booking form & API
- ☐ Encrypt Zalo credentials trong database

Phase 2: Testing & Quality (78 → 82)

- ☐ Unit tests: salary, booking, finance P&L
- ☐ Integration tests cho RLS policies
- ☐ E2E tests với Playwright
- ☐ Strongly-typed Supabase client
- ☐ CI/CD pipeline (GitHub Actions)

Phase 3: UX & Mobile (82 → 87)

- ☐ Responsive admin dashboard mobile
- ☐ Skeleton loading screens
- ☐ Global search (Cmd+K)
- ☐ Dark mode toggle
- ☐ Onboarding tour cho user mới

Phase 4: Thương mại hóa (87 → 92+)

- ☐ Self-service tenant signup flow
- ☐ Billing (VNPay/MoMo/Stripe)
- ☐ Super Admin panel cho Bella HQ
- ☐ API documentation (OpenAPI)
- ☐ PWA / App Store wrapper

Kết Luận

Bella Spa ERP đạt 72/100 — kết quả ấn tượng cho sản phẩm phát triển bởi team nhỏ trong thời gian ngắn. Hệ thống sở hữu chiều sâu nghiệp vụ vượt trội so với mọi đối thủ VN trong phân khúc spa chuyên biệt chăm sóc mẹ & bé tại nhà.

HẠNG MỤC	NHẬN ĐỊNH
Điểm mạnh cốt lõi	Feature depth vượt trội (17/20), kiến trúc multi-tenant franchise-ready, offline-first, Zalo real API, salary engine pro-rata
Cần khắc phục ngay	Bảo mật tenant isolation (hardcoded fallback), test coverage = 0%, responsive mobile admin
Tiềm năng thương mại	Hoàn thành Phase 1-2 → ra mắt SaaS ở mức giá 400-800K/tháng , cạnh tranh trực tiếp trong niche spa mẹ & bé tại nhà — niche chưa có đối thủ trực tiếp
Xếp hạng thị trường	#3 tổng thể (sau KiotViet 82, Sapo 78), #1 trong niche chuyên biệt spa mẹ & bé

